

Conformite RGPD - Projet MSPR ObRail Europe

1) Objet du document

Ce document formalise les mesures de conformite au **RGPD (UE 2016/679)** pour le projet MSPR ObRail Europe (ETL, base PostgreSQL, API FastAPI, dashboard Streamlit).

Il couvre :

- la nature des donnees traitees,
 - les finalites de traitement,
 - les mesures de securite,
 - les obligations de transparence et de gouvernance.
-

2) Responsable de traitement (cadre projet)

Dans le cadre pedagogique MSPR, le traitement est realise pour le compte du projet ObRail Europe.

- **Responsable de traitement (projet)** : Johan BILE, Joseph HACCANDY, Glody KUTUMBAKANA
 - **Perimetre** : donnees ferroviaires open data (dessertes, gares, emissions, operateurs, lignes)
 - **Contexte** : projet de formation RNCP36581
-

3) Qualification des donnees traitees

3.1 Donnees principales du projet

Le systeme traite principalement des donnees techniques et open data :

- gares (code UIC, nom, latitude, longitude, pays),
- lignes et trajets (identifiants, horaires, route),
- operateurs ferroviaires,
- indicateurs d'emissions.

3.2 Donnees personnelles

A ce stade, **aucune donnee personnelle directement identifiante** n'est necessaire au fonctionnement metier.

- Pas de nom/prenom d'utilisateur
- Pas d'email client
- Pas de telephone
- Pas d'adresse postale de personne physique

3.3 Donnees techniques de journalisation

Comme tout service web, l'infrastructure peut journaliser des metadonnees techniques :

- adresse IP source,

- horodatage,
- endpoint appele,
- code retour HTTP.

Ces donnees sont traitees pour la securite, la supervision et le diagnostic.

4) Finalites du traitement

1. **Collecter et harmoniser** des donnees ferroviaires multi-sources
 2. **Stocker et exposer** ces donnees via API REST
 3. **Visualiser** les indicateurs dans le dashboard
 4. **Produire des analyses** comparatives train vs avion
 5. **Assurer la securite** et la disponibilite du service (logs techniques)
-

5) Base(s) legale(s) (Article 6 RGPD)

Pour le perimetre actuel :

- **Interet legitime** (Art. 6.1.f) : analyse, supervision, securite technique
- **Execution d'une mission contractuelle/pedagogique** (Art. 6.1.b) dans le cadre MSPR

Si des donnees personnelles utilisateurs sont ajoutees plus tard (comptes, feedback, auth), la base legale devra etre revaluee et documentee.

6) Principes RGPD appliques

6.1 Minimisation

Le schema de donnees ne collecte que les champs necessaires a l'analyse ferroviaire.

6.2 Limitation des finalites

Les donnees sont utilisees exclusivement pour :

- exploitation ferroviaire analytique,
- visualisation et statistiques,
- maintenance technique.

6.3 Exactitude

Des controles qualite sont prevus (doublons, valeurs manquantes, coherence de format).

6.4 Limitation de conservation

Conservation adaptee au besoin pedagogique/projet. En contexte reel, definir une politique de retention explicite (ex: logs 6 a 12 mois).

6.5 Integrite et confidentialite

Mesures techniques de securite appliquees (voir section 8).

7) Transparence et information

Le projet documente :

- les sources de donnees,
- les transformations ETL,
- les endpoints API,
- les limitations fonctionnelles connues.

En contexte de production, fournir une **notice de confidentialite** publique avec :

- identite du responsable de traitement,
 - base legale,
 - droits des personnes,
 - modalites de contact.
-

8) Mesures de securite techniques et organisationnelles

Mesures deja en place :

- isolation de la base PostgreSQL,
- acces authentifie a la base (identifiant + mot de passe),
- separation backend/dashboard,
- variables sensibles en `.env` (non committees),
- journalisation des erreurs backend,
- controle des dependances Python,
- sauvegardes regulieres de la base.

Mesures a renforcer avant production :

- HTTPS obligatoire,
 - rotation des secrets,
 - chiffrement des sauvegardes,
 - supervision centralisee (alerting),
 - procedure de gestion des incidents.
-

9) Sous-traitants et transferts

9.1 Sous-traitants

Depend de l'infrastructure cible (hebergeur cloud, outil de monitoring, CI/CD). En production, contractualiser des clauses RGPD avec chaque sous-traitant.

9.2 Transfert hors UE

Non requis par défaut dans ce perimetre. Si un service hors UE est utilise, documenter le mecanisme legal (SCC, adequation, etc.).

10) Droits des personnes (Articles 12 a 22)

Si des donnees personnelles sont traitees, les droits suivants doivent etre garantis :

- droit d'accès,
- droit de rectification,
- droit a l'effacement,
- droit a la limitation,
- droit d'opposition,
- droit a la portabilite (si applicable).

Processus recommande :

- canal de demande unique (email dedie),
 - verification d'identite,
 - reponse sous 1 mois (sauf extension motivee).
-

11) Violations de donnees personnelles

Procedure type a appliquer en cas d'incident :

1. detection et qualification de l'incident,
 2. confinement technique,
 3. evaluation du risque pour les personnes,
 4. notification CNIL sous 72h si necessaire,
 5. notification des personnes concernees si risque eleve,
 6. actions correctives et preuve de remediation.
-

12) Registre des traitements (version projet)

Champ	Valeur
Nom du traitement	Plateforme d'analyse ferroviaire ObRail Europe
Finalite	Analyse flux ferroviaires et indicateurs environnementaux
Categorie de donnees	Donnees open data ferroviaires + logs techniques
Personnes concernees	Non-personnel (principalement donnees techniques)
Base legale	Interet legitime / cadre pedagogique
Destinataires	Equipe projet, encadrants, jury (dans le cadre MSPR)
Duree de conservation	Selon cycle projet + politique logs
Mesures de securite	Auth DB, segmentation, journalisation, sauvegardes

13) Plan d'actions conformite (checklist)

- ☐ Formaliser la politique de retention (BDD + logs)
 - ☐ Ajouter une politique de confidentialite publique
 - ☐ Mettre en place HTTPS de bout en bout
 - ☐ Ajouter gestion de secrets centralisee
 - ☐ Ecrire une procedure d'exercice des droits
 - ☐ Ecrire la procedure de notification d'incident
 - ☐ Auditer annuellement les dependances et acces
-

14) Clause de mise a jour

Ce document doit etre mis a jour :

- a chaque evolution majeure du schema de donnees,
 - a chaque ajout de fonctionnalite de compte utilisateur/authentification,
 - a chaque changement d'hebergement ou de sous-traitant.
-

Document RGPD - Version MSPR (2025-2026)